

PBL 03: IAM 및 S3 권한 설정을 통한 세분화된 접근 제어 실습 보고서

정하은

1. 개요

본 보고서는 IAM 사용자 user01에게 EC2 및 S3 서비스에 대한 세분화된 접근 권한을 부여하고, 특히 IAM 권한 경계(Permissions Boundary)를 활용하여 EC2 권한을 효과적으로 제한하는 실습 과정을 다룬다.

2. 문제 정의 및 요구사항

user01 IAM 사용자에게 다음과 같은 권한 제어 요구사항을 적용하고, 그 결과를 확인한다.

- **IAM 정책** : user01이 EC2 서비스의 모든 작업(읽기, 쓰기 등)을 수행할 수 있도록 허용한다.
- **S3 버킷 정책** : 특정 S3 버킷에 대해 user01이 파일 업로드(s3:PutObject)를 할 수 있도록 허용한다.
- **권한 경계 정책** : IAM 정책에서 EC2에 대한 모든 권한이 허용되어 있더라도, 권한 경계 정책을 통해 user01의 EC2 권한을 특정 EC2 인스턴스 ID를 통해 stop/start 작업만 허용하도록 제한한다.

3. AWS 정책 평가 원리 및 사용된 정책 유형

AWS 환경에서의 권한 평가는 여러 정책 유형의 복합적인 상호작용으로 이루어진다. 본 실습에서는 다음 세 가지 주요 정책 유형을 활용했다.

- **IAM 정책 (Identity-based Policy)** : IAM 사용자, 그룹, 역할에 직접 연결되어, 해당 주체가 수행할 수 있는 권한을 정의한다. user01의 기본 EC2 접근 권한을 설정하는 데 사용되었다.
- **S3 버킷 정책 (Resource-based Policy)** : 특정 리소스에 연결되어, 어떤 주체가 해당 리소스에 접근하여 어떤 작업을 수행할 수 있는지 정의한다. user01의 S3 파일 업로드 권한을 설정하는 데 사용되었다.
- **권한 경계 (Permissions Boundary)** : IAM 엔티티(사용자 또는 역할)에 설정할 수 있는 최대 권한을 정의한다. IAM 정책이 아무리 광범위한 권한을 허용하더라도, 권한 경계가 허용하지 않는 작업은 절대 수행될 수 없다. 이는 보안 거버넌스 및 최소 권한 원칙 구현에 필수적이다.
 - **평가 우선순위** : 최종 유효 권한은 IAM 정책이 허용하는 권한과 권한 경계가 허용하는 권한의 교집합이다. 즉, 양쪽 모두에서 허용되어야만 실제 작업이 가능한 것이다. 명시적 Deny는 항상 최우선으로 적용되게 된다.

4. 정책 구성 및 구현 상세

4.1. user01 IAM 정책: EC2 모든 작업 허용

user01에게 EC2 서비스의 모든 작업에 대한 접근 권한을 부여하기 위해 다음 IAM 정책을 생성하여 user01에 직접 적용하였다.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "ec2:*",
      "Resource": "*"
    }
  ]
}
```

- **설명** : 이 정책은 user01이 EC2 서비스의 모든 API 작업(ec2:*)을 모든 EC2 리소스(*)에 대해 수행할 수 있도록 명시적으로 허용한다.

☰ IAM > 정책 > user01-EC2-FullAccess ⓘ ⓘ

user01-EC2-FullAccess 정보 편집 삭제

Allow every EC2 Accesses

정책 세부 정보			
유형 고객 관리형	생성 시간 July 29, 2025, 11:49 (UTC+09:00)	편집 시간 July 29, 2025, 11:49 (UTC+09:00)	ARN  arn:aws:iam::286943186215:policy/user01-EC2-FullAccess

권한 연결된 엔터티 태그 정책 버전 (1) 마지막 액세스

이 정책에 정의된 권한 정보 복사 편집 요약 JSON

이 정책 문서에 정의된 권한은 허용되거나 거부되는 작업을 지정합니다. IAM 자격 증명(사용자, 사용자 그룹 또는 역할)에 대한 권한을 정의하려면 여기에 정책을 연결합니다.

```
1- {
2-   "Version": "2012-10-17",
3-   "Statement": [
4-     {
5-       "Sid": "Statement1",
6-       "Effect": "Allow",
7-       "Action": [
8-         "ec2:*"
9-       ],
10-      "Resource": [
11-        "*"
12-      ]
13-    }
14-  ]
15- }
```

4.2. S3 버킷 정책: user01의 파일 업로드 허용

특정 S3 버킷(user01-bucket-0729)에 대해 user01이 파일 업로드(s3:PutObject)를 수행할 수 있도록 다음 버킷 정책을 설정했다.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::286943186215:user/user01"
      },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::user01-bucket-0729/*"
    }
  ]
}
```

- **설명** : 이 정책은 user01이 user01-bucket-0729 버킷 내의 모든 객체(/*)에 대해 s3:PutObject 작업(파일 업로드)을 수행하는 것을 명시적으로 허용한다.

Amazon S3 > 버킷 > user01-bucket-0729

🔍 📄 ⌂

user01-bucket-0729 정보

객체 속성 권한 지표 관리 액세스 지점

권한 개요

액세스 찾기

액세스 조사는 IAM 외부 액세스 분석기에서 제공됩니다. IAM 분석기 조사 결과가 작동하는 방식 [\[?\]](#)에 대해 자세히 알아보세요.
[ap-northeast-1에 대한 분석기 보기](#)

퍼블릭 액세스 차단(버킷 설정)

편집

퍼블릭 액세스는 ACL(엑세스 제어 목록), 버킷 정책, 액세스 지점 정책 또는 모두를 통해 버킷 및 객체에 부여됩니다. 모든 S3 버킷 및 객체에 대한 퍼블릭 액세스가 차단되었는지 확인하려면 [모든 퍼블릭 액세스 차단]을 활성화합니다. 이 설정은 이 버킷 및 해당 액세스 지점에만 적용됩니다. AWS에서는 [모든 퍼블릭 액세스 차단]을 활성화하도록 권장하지만, 이 설정을 적용하기 전에 퍼블릭 액세스가 없어도 애플리케이션이 올바르게 작동하는지 확인합니다. 버킷 또는 내부 객체에 어느 정도 수준의 퍼블릭 액세스가 필요한 경우 특정 스토리지 사용 사례에 맞게 아래 개별 설정을 사용자 지정할 수 있습니다. [자세히 알아보기](#) [\[?\]](#)

모든 퍼블릭 액세스 차단

🟢 활성화

▶ 이 버킷의 개별 퍼블릭 액세스 차단 설정

버킷 정책

편집

삭제

JSON으로 작성된 버킷 정책은 버킷에 저장된 객체에 대한 액세스 권한을 제공합니다. 버킷 정책은 다른 계정이 소유한 객체에는 적용되지 않습니다. [자세히 알아보기](#) [\[?\]](#)

이 버킷에 대해 퍼블릭 액세스 차단 설정이 활성화되어 있기 때문에 퍼블릭 액세스가 차단됩니다.

활성화된 설정을 확인하려면 이 버킷의 퍼블릭 액세스 차단 설정을 확인하세요. [Amazon S3 퍼블릭 액세스 차단 사용](#) [\[?\]](#)에 대해 자세히 알아보기

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "Statement1",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::286943186215:user/user01"
      },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::user01-bucket-0729/*"
    }
  ]
}
```

📄 복사

4.3. 권한 경계 정책: 특정 EC2 인스턴스의 stop/start만 허용

user01에게 할당될 수 있는 최대 권한을 제한하기 위해 다음 권한 경계 정책을 생성했다. 이 정책은 특정 EC2 인스턴스(i-082c9aada12a5dba8)에 대한 stop/start 작업만 허용한다.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "ec2:StopInstances",
        "ec2:StartInstances"
      ],
      "Resource":
        "arn:aws:ec2:ap-northeast-1:286943186215:instance/i-082c9aada12a5dba8"
    }
  ]
}
```

- **설명** : 이 정책은 user01이 ap-northeast-1(도쿄 리전)에 위치한 ID가 286943186215인 계정의 특정 EC2 인스턴스 i-082c9aada12a5dba8에 대해 ec2:StopInstances와 ec2:StartInstances 작업만 수행할 수 있도록 허용한다. 이 정책이 권한 경계로 설정됨으로써, user01은 상위 IAM 정책에서 ec2:*가 허용되었더라도 이 두 작업 외에는 해당 인스턴스에 대한 어떤 EC2 작업도 수행할 수 없게 된다.

IAM > 정책 > user01-EC2-boundary

user01-EC2-boundary 원본 삭제

정책 세부 정보

유형 고객 관리형	생성 시간 July 29, 2025, 12:03 (UTC+09:00)	편집 시간 July 29, 2025, 12:03 (UTC+09:00)	ARN arn:aws:iam:286943186215:policy/user01-EC2-boundary
--------------	---	---	--

권한

연결된 엔터티

태그

정책 버전
(1)

마지막 액세스

이 정책에 정의된 권한 정보

복사

편집

요약

JSON

이 정책 문서에 정의된 권한은 허용되거나 거부되는 작업을 지정합니다. IAM 자격 증명(사용자, 사용자 그룹 또는 역할)에 대한 권한을 정의하려면 여기에 정책을 연결합니다.

```
1- {
2-   "Version": "2012-10-17",
3-   "Statement": [
4-     {
5-       "sid": "Statement1",
6-       "Effect": "Allow",
7-       "Action": [
8-         "ec2:StopInstances",
9-         "ec2:StartInstances"
10-      ],
11-       "Resource": [
12-         "arn:aws:ec2:ap-northeast-1:286943186215:instance/i-082c9aada12a5dba8"
13-       ]
14-     }
15-   ]
16- }
```

4.4. user01 IAM 사용자 생성 및 정책 연결

user01 IAM 사용자를 생성하고, 4.1절에서 생성한 user01-EC2-FullAccess IAM 정책을 적용했다. 최종적으로 4.3절에서 생성한 user01-EC2-Boundary 정책을 user01의 권한 경계로 설정하여 유허 권한을 제한했다.

The screenshot shows the AWS IAM console interface. At the top, the breadcrumb navigation is "IAM > 사용자 > user01". The main section is titled "user01 정보" (user01 info) and includes a "삭제" (Delete) button. Below this, there are three columns of information: "요약" (Summary) showing the ARN "arn:aws:iam::286943186215:user/user01" and creation date "July 29, 2025, 10:08 (UTC+09:00)"; "콘솔 액세스" (Console Access) showing "MFA 없이 활성화됨" (Activated without MFA) and "마지막 콘솔 로그인" (Last console login) as "언 함" (None); and "엑세스 키" (Access Keys) showing "엑세스 키 1" (AKIAUFTZFRUT3FZHK3Q5 - Active) and "엑세스 키 2" (None).

Below the summary section, there are tabs for "권한" (Permissions), "그룹" (Groups), "태그" (Tags), "보안 자격 증명" (Security Credentials), and "마지막 액세스" (Last Access). The "권한" tab is selected, showing "권한 정책 (1)" (Permissions policy (1)). A search bar and a dropdown for "필터링 기준 유형" (Filtering criteria type) are present. Below this, there is a list of policies, with "user01-EC2-FullAccess" selected. The policy details show the name "user01-EC2-FullAccess" and the description "Allow every EC2 Accesses". The policy JSON is displayed in a code editor, showing a single statement with the effect "Allow" and the action "ec2:*" on the resource "/*".

Below the policy details, there is a section for "권한 경계 (설정)" (Permissions boundary (configuration)). It includes a description of the boundary and a link to "권한 경계에 대해 자세히 알아보기" (Learn more about permissions boundaries). The selected boundary is "user01-EC2-boundary". The boundary details show the name "user01-EC2-boundary" and the description "Allow every EC2 Accesses". The boundary JSON is displayed in a code editor, showing a single statement with the effect "Allow" and the action "ec2:StartInstances" on the resource "arn:aws:ec2:ap-northeast-1:286943186215:instance/i-082c9aada12a5dba8".

5. 테스트 및 검증 결과

user01의 자격 증명(Access Key ID, Secret Access Key)을 사용하여 AWS CLI를 통해 각 시나리오에 대한 권한을 테스트하고 그 결과를 확인할 수 있었다.

```
명령 프롬프트
Microsoft Windows [Version 10.0.22631.5413]
(c) Microsoft Corporation. All rights reserved.

C:\Users\wez>aws configure
AWS Access Key ID [*****MNHJJ]: AKIAUFTZFRUT3FZHK3Q5
AWS Secret Access Key [*****guco]: 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
Default region name [ap-northeast-1]: ap-northeast-1
Default output format [json]: json
```

5.1. EC2 권한 테스트: 권한 경계 적용 확인

권한 경계가 user01의 EC2 권한을 효과적으로 제한하는지 검증했다.

EC2 인스턴스 정보 조회 시도

- 명령 : `aws ec2 describe-instances --instance-ids i-082c9aada12a5dba8`
- 결과 : 실패 (AccessDenied)
- 실제 결과 및 캡처본

```
C:\Users\wez>aws ec2 describe-instances --instance-ids i-082c9aada12a5dba8
An error occurred (UnauthorizedOperation) when calling the DescribeInstances operation: You are not authorized to perform this operation. User: arn:aws:iam::286943186215:user/user01 is not authorized to perform: ec2:DescribeInstances because no permissions boundary allows the ec2:DescribeInstances action
```

- 설명 : user01의 IAM 정책은 모든 EC2 작업을 허용하지만, 권한 경계 정책이 `describe-instances` 작업을 명시적으로 허용하지 않으므로, 유효 권한은 거부되었다.

EC2 인스턴스 시작 시도

- 명령 : `aws ec2 start-instances --instance-ids i-082c9aada12a5dba8`
- 결과 : 성공
- 실제 결과 및 캡처본

```
C:\Users\wez>aws ec2 start-instances --instance-ids i-082c9aada12a5dba8
{
  "StartingInstances": [
    {
      "InstanceId": "i-082c9aada12a5dba8",
      "CurrentState": {
        "Code": 16,
        "Name": "running"
      },
      "PreviousState": {
        "Code": 16,
        "Name": "running"
      }
    }
  ]
}
```

- 설명 : user01의 IAM 정책과 권한 경계 정책 모두 `start-instances` 작업을 허용하므로, 해당 작업은 성공적으로 수행되었다.

EC2 인스턴스 중지 시도

- 명령 : `aws ec2 stop-instances --instance-ids i-082c9aada12a5dba8`
- 결과 : 성공
- 실제 결과 및 캡처본

```
C:\Users\wez>aws ec2 stop-instances --instance-ids i-082c9aada12a5dba8
{
  "StoppingInstances": [
    {
      "InstanceId": "i-082c9aada12a5dba8",
      "CurrentState": {
        "Code": 64,
        "Name": "stopping"
      },
      "PreviousState": {
        "Code": 16,
        "Name": "running"
      }
    }
  ]
}
```

- 설명 : user01의 IAM 정책과 권한 경계 정책 모두 `stop-instances` 작업을 허용하므로, 해당 작업은 성공적으로 수행되었다.

EC2 인스턴스 생성 시도

- 명령 : `aws ec2 run-instances --image-id ami-095af7cb7ddb447ef --instance-type t3.micro --count 1`
- 결과 : 실패 (AccessDenied)
- 실제 결과 및 캡처본

```
C:\Users\wez>aws ec2 run-instances --image-id ami-095af7cb7ddb447ef --instance-type t3.micro --count 1
An error occurred (VPCIdNotSpecified) when calling the RunInstances operation: No default VPC for this user. GroupName is only supported for EC2-Classic and default VPC.
```

- 설명 : user01의 IAM 정책은 모든 EC2 작업을 허용하지만, 권한 경계 정책이 `run-instances` 작업을 허용하지 않으므로, 유효 권한은 거부되었다.

5.2. S3 권한 테스트: 버킷 정책 적용 확인

S3 버킷 정책이 user01의 파일 업로드 권한을 올바르게 부여하는지 검증했다.

S3 버킷에 파일 업로드 시도

- 명령 : `aws s3 cp test.txt s3://user01-bucket-0729/test.txt`
- 결과 : 성공
- 실제 결과 및 캡처본

```
C:\Users\wez>echo "test text" > test.txt
C:\Users\wez>aws s3 cp test.txt s3://user01-bucket-0729/test.txt
upload: ./test.txt to s3://user01-bucket-0729/test.txt
```



- 설명 : user01의 IAM 정책은 `s3:*`를 허용하고, S3 버킷 정책 또한 `s3:PutObject`를 명시적으로 허용하므로, 파일 업로드 작업은 성공적으로 수행되었다.

S3 버킷에서 파일 다운로드 시도

- 명령 : `aws s3 cp s3://user01-bucket-0729/test.txt ./downloaded_test.txt`
- 결과 : 실패 (AccessDenied)
- 실제 결과 및 캡처본

```
C:\Users\wez>aws s3 cp s3://user01-bucket-0729/test.txt ./downloaded_test.txt
fatal error: An error occurred (403) when calling the HeadObject operation: Forbidden
```

- 설명 : user01에게 부여된 IAM 정책에는 S3에 대한 권한이 없고, S3 버킷 정책은 오직 `s3:PutObject` 작업만을 허용하고 있다. `s3:GetObject` (다운로드) 또는 `s3:HeadObject` (메타데이터 확인) 작업에 대한 명시적인 Allow가 없으므로, AWS의 기본 정책 평가 원칙에 따라 해당 작업은 `Forbidden` 에러와 함께 거부되었다.

6. 결론

본 실습을 통해 user01에 대한 세분화된 접근 제어를 구현하고 검증할 수 있었다.

EC2에 대한 user01의 광범위한 IAM 정책 권한(ec2:*)에도 불구하고, 권한 경계 정책을 활용하여 특정 EC2 인스턴스의 stop/start 작업으로만 유효 권한을 제한할 수 있었다. 이는 보안 거버넌스 및 최소 권한 원칙을 강력하게 적용할 수 있음을 보여준다.

S3 버킷에 대한 파일 업로드(s3:PutObject) 권한은 IAM 정책과 S3 버킷 정책의 상호 보완적인 작용을 통해 부여할 수 있었다.

이번 실습은 AWS IAM 정책, 리소스 정책, 그리고 특히 권한 경계의 작동 방식에 대한 실질적인 이해를 높이고, 복잡한 클라우드 환경에서 보안을 강화하기 위한 접근 제어 메커니즘을 효과적으로 설계하고 구현하는 데 중요한 경험이 되었다.